

Berth

Engineering work, releases, and deployment history - docked.

DevSecOps Final Capstone · Session 21 · github.com/Maverick-sst/Berth

WHAT BERTH IS BUILT WITH

Tech stack



Python 3.12



FastAPI



SQLAlchemy 2



PostgreSQL 16



React 18 + Vite



nginx (unprivileged)



Docker Compose



GitHub Actions



Trivy gate



Terraform



Kubernetes

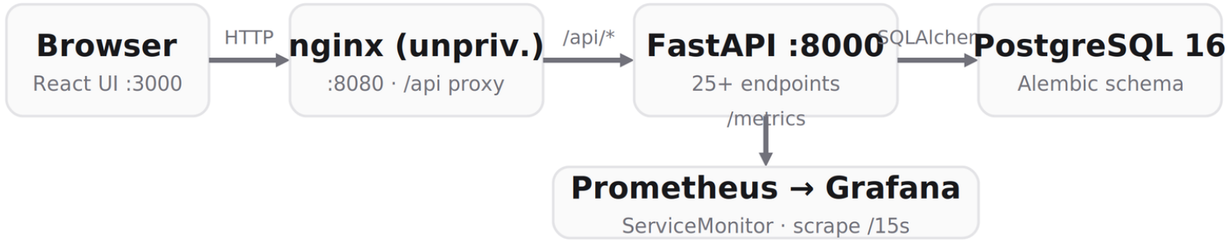


Helm

Prometheus + Grafana for observability · GHCR for immutable SHA-tagged images · kind for pipeline smoke tests

REQUEST & DATA FLOW

Architecture




```
$ curl localhost:8000/health   {"status":"UP"}
$ curl localhost:8000/ready    {"status":"READY"}   <- checks the DB
$ curl localhost:8000/metrics  # HELP http_requests_total ...
```

What Berth actually does

- **Projects** group tasks; deleting a project with tasks is refused (409).
- **Tasks** TODO -> IN_PROGRESS -> DONE, priorities, assignees, due dates, search, pagination.
- **Comments & activity** persisted discussion per task; every action writes a real ActivityEvent.
- **Releases** PLANNED -> READY -> DEPLOYING -> DEPLOYED / FAILED (see the state machine below).
- **Deployment history** environment, commit SHA, outcome, timestamps, failure reason - failures are first-class.



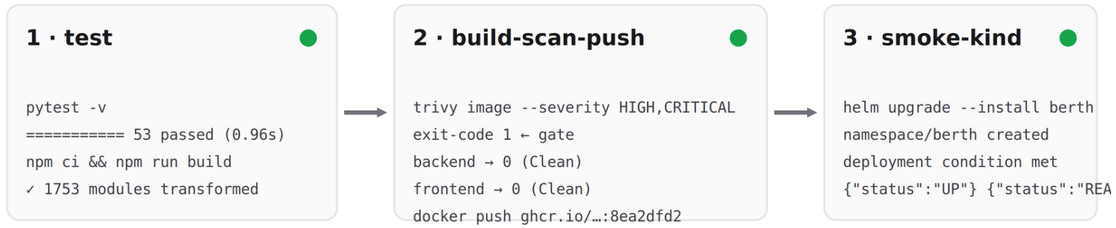
Illegal jumps (e.g. PLANNED → DEPLOYED) are rejected server-side with 409.
Readiness = every attached task DONE + at least one task. Computed, never faked.

```
$ PUT /api/releases/1 {"status":"DEPLOYED"} → 409 (illegal transition)
$ POST /api/deployments/<id>/finish {"status":"FAILED"} without reason → 422
```

GITHUB ACTIONS · REAL PIPELINE LOG

CI/CD - the run that shipped this deck's numbers

```
Run backend tests    ============================== 53 passed, 1 warning in 0.96s
Scan backend image   Report Summary -> backend 0 (Clean)  |  frontend 0 (Clean)
Push backend image   8ea2dfd26222f...: digest: sha256:5fc7502a7628483c...
Smoke test API       {"status":"UP"}   {"status":"READY"}
```



Pushes only · real-cluster deploys stay manual per docs/CLOUD_RUNBOOK.md · no cloud credentials in CI

```
$ ghcr.io/maverick-sst/berth/berth-backend:8ea2dfd26222f939a49f132e4b0bfb29fdb615ba
$ ghcr.io/maverick-sst/berth/berth-frontend:8ea2dfd26222f939a49f132e4b0bfb29fdb615ba
```

Published from the green run · immutable commit-SHA tags.

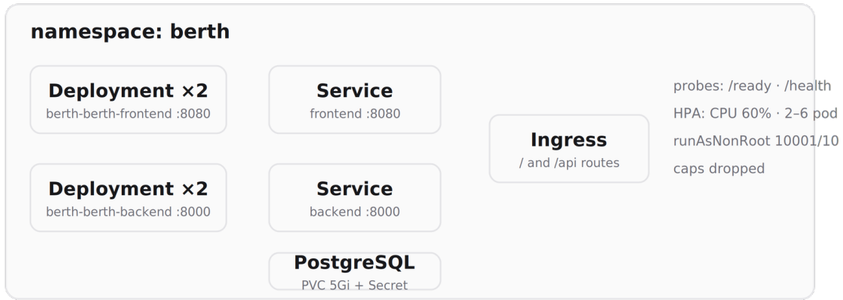
TERRAFORM - AWS

Infrastructure as Code

- **VPC** 10.20.0.0/16, 2 public + 2 private subnets, single NAT gateway.
- **EKS** v1.31, managed t3.medium node group (2-4 nodes).
- **Validated statically** - terraform fmt -check and terraform validate pass; no blind apply.
- **Cost honesty** - ~$150-220/month while running; runbook: plan -> user-approved apply -> destroy.
- **terraform.tfvars.example** only placeholders; real values stay out of git.

HOW BERTH RUNS IN A CLUSTER

Kubernetes + Helm




```
$ namespace/berth created · deployment.apps/berth-berth-backend condition met
```

REAL CVE STORY FROM THIS PROJECT

DevSecOps: the security gate earns its keep

First run: gate FAILS (exit code 1)

```
Total: 3 (HIGH: 3, CRITICAL: 0) starlette 0.41.3
CVE-2025-62727 HIGH DoS via Range header fixed 0.49.1
CVE-2026-48818 HIGH SSRF / NTLM theft fixed 1.1.0
CVE-2026-54283 HIGH form() limits ignored fixed 1.3.1
```

Response: fix, don't ignore

```
fastapi 0.115.6 → 0.143.0 · starlette → 1.3.1 · instrumentator 7 → 8
+ apk/apt upgrade in both Dockerfiles (base images freeze packages)
```

```
Final run: backend 0 · frontend 0 → published to GHCR
```

PROMETHEUS + GRAFANA

Observability



Prometheus



Grafana

- **Instrumentation** prometheus-fastapi-instrumentator exposes /metrics on the backend.
- **Discovery** ServiceMonitor finds the app in any namespace (kube-prometheus-stack values).
- **Dashboard** importable JSON - request rate, p95 latency, error rate, status-code breakdown.
- **Verified, not assumed** - runbook steps confirm the target is UP and panels are populated.
- **Load demo** scripts/load-test.sh generates traffic so panels come alive on screen.

WHAT KEEPS BERTH HONEST

Quality gates

✓ **53 pytest tests**

8+ endpoints, isolated in-memory DB

✓ **Alembic authoritative**

4 migrations, no create_all in prod

✓ **Non-root containers**

uid 10001 backend / 101 nginx

✓ **State machines**

release transitions validated (409)

✓ **Protected deletes**

no orphaned or cascaded data

✓ **Zero secrets in git**

placeholders + runtime injection

Plus: token-gated CI deployment reports (hmac.compare_digest) · real activity only - no fabricated feed or metrics

Key learnings

- **Migrations own the schema.** create_all at startup hides drift; Alembic up/down/up on every change.
- **Security gates must fail builds.** Trivy caught 3 HIGH starlette CVEs - fixed by upgrading, not ignoring.
- **Base images go stale.** 41 frontend CVEs traced to frozen packages - apk/apt upgrade at build time.
- **Fabricated data is a smell.** if a dashboard can't be trusted, it isn't a dashboard.
- **Least privilege everywhere.** no cloud creds in CI; GITHUB_TOKEN with packages:write is enough.



Thank you

Berth - engineering work, docked.

github.com/Maverick-sst/Berth · 52 commits · 53 tests · 2 clean images on GHCR